

Aula 1 (Módulo 08) — Estrutura de SOC, Workflow e Alert Triage

1. O que é um SOC (visão simples)

SOC (*Security Operations Center*) é o time/estrutura responsável por **monitorar continuamente** o ambiente de uma organização em busca de sinais de ataque, e **responder** quando algo é encontrado. Pense nele como uma torre de controle: várias telas mostrando alertas em tempo real, gerados por tudo que já estudamos (Windows Event Logs, Sysmon, Suricata, firewall, proxy...), consolidados em um **SIEM** (Módulo 09) — e um time de pessoas decidindo, alerta por alerta, o que fazer.

2. Os níveis de um SOC (N1, N2, N3)

A maioria dos SOCs organiza o time em **níveis** (ou *tiers*), cada um com responsabilidade e profundidade de análise diferentes:

N1 — Triage (Tier 1)

- **O que faz:** recebe os alertas gerados pelo SIEM/ferramentas, faz uma análise **inicial e rápida**: o alerta parece um falso positivo óbvio, ou parece real e merece atenção?
- **Habilidade central:** seguir **runbooks/playbooks** (procedimentos documentados passo a passo) e reconhecer padrões já vistos.
- **Decisão:** fechar o alerta (falso positivo claro) ou **escalar** para N2.

N2 — Investigação aprofundada (Tier 2)

- **O que faz:** pega os alertas escalados pelo N1 e faz investigação de verdade — correlaciona múltiplas fontes de log, entende o **contexto** completo (é isso normal para esse usuário/host? já aconteceu antes?), determina se é um **incidente real**.
- **Habilidade central:** pensamento investigativo, conhecimento profundo de sistemas/rede (tudo que estudamos até aqui), capacidade de reconstruir uma linha do tempo de ataque.
- **Decisão:** fechar como falso positivo com justificativa técnica mais robusta, ou confirmar como incidente e acionar resposta (Módulo 15).

N3 — Especialistas / Threat Hunting (Tier 3)

- **O que faz:** os casos mais complexos, investigações profundas de incidentes já confirmados, **Threat Hunting** proativo (Módulo 14 — procurar ameaças que **nenhum** alerta automático detectou ainda), e muitas vezes também constrói/ajusta as regras de detecção que o N1/N2 usam (conectando com Detection Engineering, Módulo 21).
- **Habilidade central:** profundidade técnica muito alta, capacidade de criar hipóteses de investigação do zero, sem um alerta apontando o caminho.

Por que essa estrutura existe: volume. Um SOC de uma empresa média pode receber **milhares** de alertas por dia — a maioria falsos positivos ou ruído de baixa severidade. Sem uma estrutura em camadas, seria impossível dar atenção

profunda a tudo. N1 filtra o volume; N2 investiga o que realmente importa; N3 lida com o que exige especialização. É comum começar a carreira em N1 e evoluir para N2/N3 com experiência.

3. O workflow de um alerta, do início ao fim

1. Ferramenta gera evento (Sysmon, firewall, EDR...)
2. SIEM correlaciona/normaliza e dispara um ALERTA (Módulo 09)
3. Alerta cai na fila do N1
4. N1 faz TRIAGE: contexto rápido, runbook, decide: FP óbvio? ou escalar?
5. Se escalado → N2 investiga a fundo
6. N2 decide: FP (fecha, documenta o motivo) ou TP (incidente confirmado)
7. Se TP → aciona processo de Incident Response (Módulo 15)
8. Todo o processo é documentado no sistema de CASE MANAGEMENT (ticket)

Por que importa: cada etapa desse workflow gera **documentação** — não é só "resolver e esquecer". Isso permite medir tendências (esse tipo de alerta aumentou esse mês?), auditar decisões (por que esse alerta foi fechado como FP?), e treinar analistas novos com casos reais anteriores.

4. Alert Triage — a habilidade central do N1

Triagem é responder, rapidamente, a perguntas como:

- Esse alerta é **conhecido**? Já vi esse padrão antes e sei que é normal para esse ambiente (ex.: um scanner de vulnerabilidade autorizado gerando tráfego "suspeito" todo dia às 2h da manhã)?
- O **contexto** faz sentido? (Lembra do Logon Type do Módulo 02, Aula 4 — um Logon Type 10 (RDP) de uma conta de serviço que nunca faz login interativo é diferente de um Logon Type 10 de um analista de TI que sempre acessa remotamente.)
- Existe **informação suficiente** no alerta para decidir, ou é preciso pivotar para outra fonte de dados (outro log, outra ferramenta) antes de decidir?

Isso conecta diretamente com tudo que já estudamos: um alerta de "processo filho incomum" só faz sentido triado por quem entende a relação pai/filho (Módulo 00, Aula 1); um alerta de "falha de login em massa" só faz sentido para quem entende brute force (Módulo 01, Aula 4).

5. Escalation — quando e como escalar

Escalar não é "não saber resolver" — é reconhecer os **limites da própria análise** e trazer alguém com mais contexto/ferramentas. Boas práticas de escalção:

- Documentar **o que já foi verificado** antes de escalar (evita que o N2 repita o mesmo trabalho do zero).
- Escalar com a **severidade correta** (Aula 2) — escalar tudo como crítico gera fadiga de alerta no time; escalar tudo como baixo atrasa resposta a incidentes reais.
- Escalar **rápido** quando há sinais fortes de comprometimento ativo — não é hora de "ter certeza absoluta" antes de avisar alguém.

6. Conectando com tudo que já estudamos

```
Alerta chega → N1 usa TUDO dos Módulos 00-07 para reconhecer padrões
                (processo pai/filho, Event ID, IP privado vs. público,
                command line suspeita, hash conhecido...)
                → decide: FP claro (fecha) ou escala
N2 investiga → correlaciona múltiplas fontes, reconstrói timeline
N3           → casos complexos, hunting proativo, cria novas detecções
```

Todo o conhecimento técnico dos módulos anteriores existe, em última análise, para **alimentar** esse processo de triagem e investigação.

7. Exercício de reflexão

Pense num cenário: você é N1 e recebe um alerta dizendo "PowerShell executado com flag `-EncodedCommand` , processo pai: `outlook.exe` ". Usando **só** o que já vimos nos módulos anteriores (sem eu te dar a resposta):

1. Isso te lembra algum padrão que já estudamos? Qual?
2. Que outras informações você pediria antes de decidir se escala ou não (pense em: usuário, horário, hash do processo, conexões de rede geradas)?
3. Você fecharia como FP, ou escalaria para N2? Justifique.

Quando quiser, me chame para fazer uma simulação de verdade — vou te entregar um `ALERTA #001` formatado (timestamp, hostname, usuário, IP, processo, evento, severidade) e você investiga de verdade, com dados que vou fornecendo conforme você pedir, sem eu entregar a resposta de cara.

8. Recapitulando

- SOC = time que monitora continuamente e responde a ameaças; níveis N1 (triagem) → N2 (investigação) → N3 (especialistas/hunting).
- Workflow: evento → SIEM correlaciona → alerta → N1 triage → escala ou fecha → N2 investiga → TP vira incidente (Módulo 15).
- Triagem usa todo o conhecimento técnico prévio para reconhecer padrões normais vs. suspeitos rapidamente.
- Escalar é reconhecer limites, não fraqueza — deve vir documentado e com severidade correta.

Próxima aula

TP vs. FP, severidade, priorização, case management e SLA — como formalizar as decisões que a triagem toma, e como isso vira métrica de performance de um SOC.

Fontes recomendadas

- **NIST SP 800-61 Rev. 2 — "Computer Security Incident Handling Guide"**: referência oficial de estrutura de resposta a incidentes, incluindo papéis de um time de segurança. <https://csrc.nist.gov/pubs/sp/800/61/r2/final>
- **CISA — "Cybersecurity Incident & Vulnerability Response Playbooks"**: playbooks oficiais de referência para resposta e triagem. <https://www.cisa.gov/resources-tools/resources/federal-government-cybersecurity-incident-and-vulnerability-response-playbooks>